

Procédure de Confinement des Incidents de Sécurité

1. Objet

Cette procédure définit les actions à entreprendre afin de contenir rapidement un incident de sécurité informatique, de limiter sa propagation et de réduire son impact sur les systèmes, les données et les activités de l'entreprise.

2. Champ d'application

Cette procédure s'applique à l'ensemble des systèmes d'information, équipements, applications, réseaux et utilisateurs de l'entreprise.

3. Déclenchement de la procédure

La procédure de confinement est activée dès qu'un incident de sécurité est détecté ou suspecté, notamment dans les cas suivants :

- Infection par un logiciel malveillant (virus, ransomware, cheval de Troie).
- Compromission d'un compte utilisateur ou administrateur.
- Intrusion sur le réseau ou un système.
- Fuite ou exfiltration de données.
- Activité anormale détectée par les outils de supervision.
- Attaque par déni de service (DoS/DDoS).

4. Rôles et responsabilités

Responsable Sécurité des Systèmes d'Information (RSSI)

- Évalue la gravité de l'incident.
- Coordonne les actions de confinement.
- Informe la direction et les parties prenantes concernées.

Équipe Informatique

- Exécute les mesures techniques de confinement.
- Collecte les preuves nécessaires à l'investigation.
- Assure le suivi des systèmes affectés.

Utilisateurs

- Signalent immédiatement tout comportement suspect.
- Respectent les consignes de sécurité communiquées.

5. Procédure de confinement

5.1 Identification de l'incident

1. Recevoir l'alerte provenant d'un utilisateur, d'un système de détection ou d'un prestataire.
2. Vérifier et qualifier l'incident.
3. Déterminer les actifs impactés.

5.2 Confinement immédiat

Selon la nature de l'incident :

Poste de travail compromis

- Déconnecter immédiatement le poste du réseau.
- Désactiver les connexions Wi-Fi et VPN.
- Empêcher toute utilisation du système jusqu'à analyse.

Compte utilisateur compromis

- Désactiver ou verrouiller le compte concerné.
- Réinitialiser les mots de passe associés.
- Révoquer les sessions actives.

Serveur compromis

- Isoler le serveur du réseau.
- Bloquer les flux entrants et sortants non essentiels.
- Conserver les journaux et preuves numériques.

Incident réseau

- Bloquer les adresses IP malveillantes.
- Mettre à jour les règles de pare-feu.
- Segmenter temporairement le réseau si nécessaire.

5.3 Préservation des preuves

- Sauvegarder les journaux systèmes et applicatifs.
- Capturer les informations mémoire si nécessaire.
- Documenter toutes les actions réalisées.
- Conserver les preuves conformément aux procédures internes.

5.4 Communication

- Informer le RSSI et la direction.
- Informer les équipes concernées selon le besoin.
- Si nécessaire, notifier les autorités compétentes conformément aux obligations réglementaires.

6. Validation du confinement

Le confinement est considéré comme effectif lorsque :

- La propagation de l'incident est stoppée.
- Les systèmes affectés sont isolés.
- Les comptes compromis sont sécurisés.
- Les risques immédiats sont maîtrisés.

7. Passage à l'éradication et à la restauration

Une fois le confinement validé :

1. Identifier la cause racine.
2. Supprimer les éléments malveillants.
3. Corriger les vulnérabilités exploitées.
4. Restaurer les systèmes à partir de sauvegardes fiables.
5. Effectuer des tests de sécurité avant remise en production.

8. Retour d'expérience

À l'issue de l'incident :

- Réaliser un rapport d'incident.
- Identifier les axes d'amélioration.
- Mettre à jour les procédures de sécurité.
- Sensibiliser les utilisateurs si nécessaire.

9. Révision de la procédure

Cette procédure est revue au minimum une fois par an ou après tout incident majeur de sécurité.